

1. 업무개요

수도권서부환경본부(♣♣♣♣♣처, 이하 “♣♣♣♣♣처”라 함)는 대기환경보전법 제32조(측정기기의 부착 등)에 따라 사업자 배출시설에서 나오는 오염 물질이 배출허용기준에 맞는지를 확인하기 위하여 측정기기를 부착하는 등의 조치를 하여 배출시설과 방지시설이 적정하게 운영되도록 하는 업무를 수행하고, 대기관리권역의 대기환경개선에 관한 특별법 제17조(배출허용총량의 할당 등)에 따라 사업장 총량관리대상 오염물질 배출허용총량을 관리하고 있다.

그리고, 기후대기본부(●●●●●처, 이하 “●●●●●처”라 함)는 총량관리사업자가 배출량을 측정하기 위하여 사업장에 부착한 측정기기와 연결하여 그 측정 결과를 전산 처리할 수 있도록 -----시스템(시스템, 이하 “시스템”이라 함) 누리집(<https://www.-----.-.-.->)을 운영하고 있다.

[그림 1] 누리집 및 운영시스템 화면

<생략>	<생략>
누리집	운영시스템

2. 관련규정 및 판단기준

「개인정보의 안정성 확보조치 기준」(-----회 고시 제0000-0호) 제6조(접근통제) 제2항에서 개인정보처리자는 개인정보취급자가 정보통신망을 통해 외부에서 개인정보처리시스템에 접속하려는 경우 인증서, 보안토큰, 일회용 비밀번호(OTP) 등 안전한 인증수단을 적용하도록 정하고 있다.

또한, ☆☆ 「정보보안 업무지침」 제77조(비밀번호 관리) 제3항에는 공용 정보시스템에서 개별사용자를 식별 또는 인증하기 위하여 비밀번호에 갈음하거나 병행하여 지문인식 등 생체인증 기술 및 일회용 비밀번호 생성기(OTP) 등을 안전성 확인 후 사용할 수 있다고 명시되어 있다.

●●●●●처에서는 0000년 시스템 개선 사업을 추진하였고, 기존 사용하던 로그인 방식(ID/Password)에 대한 사용자 계정 인증 보안 취약점 개선을 위해 OTP 인증 방식의 이중 인증체계를 도입하여 운영해 오고 있다.

[표 1] 0000년 시스템 개선 사업 개요

구분	내용
사업명	- ---- ---- -- --시스템 개선
사업기간	- 0000. 0. 0 ~ 0000. 00. 00.
사업비	- 0,000백만원
사업배경 및 목적	- 클린시스 및 대기오염총량 노후 전산시스템 교체 - 측정기기 통신방식 디지털화로 대용량 서버 장비를 도입 - 응용프로그램 사용자의 편의성을 도모를 위한 기능 개선

3. 감사결과 확인된 문제점

그러나, 수도권서부환경본부 종합감사 중 ♣♣♣♣♣처가 사용하고 있는 시

시스템의 인증 정책 사용 현황을 확인한 결과, 사업장의 단순 조회 기능을 가진 계정을 제외한 사업장 담당자 및 부 등 외부 사용자 계정에 대해서는 공인인증서 및 OTP의 추가 인증 정책이 적용(전체 0,000개 중 0,000개, 00%)되어 있는 반면, ☆☆ 운영자 계정은 대부분(전체 000개 중 000개, 00%)이 기존 로그인 방식(ID/Password)을 사용하도록 인증 정책을 운영 중인 것으로 확인되었다.

[표 2] 시스템 인증 정책 사용 현황

구분		인증정책	계정수(개)	비율(%)
계			0,000	—
사업장	담당자	ID/PW	0	0.0
		공인인증서	0,000	00.0
		OTP	000	00.0
	조회자 (단순 조회 기능)	ID/PW	000	00.0
		공인인증서	—	—
		OTP	0	0.0
☆☆	운영자	ID/PW	000	0.0
		공인인증서	0	0.0
		OTP	0	0.0
 부 등		ID/PW	00	0.0
		공인인증서	0	0.0
		OTP	000	0.0

따라서, 데이터 도난·유출 및 맬웨어¹⁾ 전달 등의 문제를 발생시킬 수 있는 계정 탈취 문제를 예방하기 위해 ☆☆ 운영자 계정에 보안토큰, 일회용 비밀번호(OTP), 간편 인증 등 안전한 인증수단 체계를 적용하여 시스템 보안 관리를 강화할 필요가 있다.

1) 사용자의 이익을 침해하는 모든 악성 소프트웨어. 감염된 컴퓨터 또는 기기는 물론, 감염된 기기가 통신할 수 있는 다른 기기까지 영향을 줄 수 있음

4. 조치할 사항

기후대기이사(●●●●●처장)는 -----시스템의 사용자 계정 인증 보안 취약점 개선을 하기 위한 방안을 마련하시기 바랍니다. 【권고】